

What Good Looks Like

Company: [COMPANY NAME]

Review owner: [AI GOVERNANCE LEAD]

Review date:

How to use. Use this document at the end of the first setup pass. It helps you decide whether the combined governance and risk assessment packet is complete enough to use, what still needs review, and what belongs in the next phase.

The outcome you are aiming for

After the first pass, your team should be able to answer these questions without searching through chat threads:

1. What AI tools are we using?
2. Who owns each tool or workflow?
3. What data is allowed or prohibited for each tool?
4. Which tools are approved, under review, or not approved?
5. Which AI uses need review before launch or expansion?
6. Which higher-risk workflows have an intake or impact assessment record?
7. What AI risks are being tracked, who owns them, and when are they reviewed?
8. Where do we record vendor, model, prompt, workflow, and policy changes?
9. Where do staff ask AI use questions?

If you can answer those questions, the packet is doing its job.

First-pass scorecard

Area	Not started	Drafted	In use	Needs review	Evidence / link
AI Use Inventory					
Approved tools list					
AI Acceptable Use Policy					
Green / Yellow / Red rules					
New tool review path					
Risk tiering decision path					
AI Risk Intake and Impact Assessment					
AI Risk Register					
AI Update Tracker					
Staff rollout message					

First governance meeting					
Open legal/privacy/security questions					

Done enough for first pass

The packet is done enough for first pass when:

- ☐ The inventory includes known work-related AI tools
- ☐ Each active tool has a business owner
- ☐ Staff know which tools are approved
- ☐ Staff know what data must not go into unapproved AI tools
- ☐ There is a review path for new AI tools or workflows
- ☐ Higher-risk workflows are tiered and flagged for deeper review
- ☐ At least one higher-risk workflow has an intake or impact assessment record, if higher-risk use exists
- ☐ Material AI risks have a place to be tracked
- ☐ AI changes have a place to be logged
- ☐ The first rollout message has been sent or scheduled
- ☐ Open questions have owners and due dates

Done enough does not mean legally complete. It means the team has moved from informal AI use to a visible, managed first pass.

Not done yet if...

- People are still using unknown AI tools for work
- Nobody owns the inventory
- The approved tools list is unclear
- Sensitive data rules are not written down
- Staff do not know where to ask questions
- Customer-facing or decision-related AI use has not been reviewed
- Higher-risk AI use has no documented tier or risk owner
- Vendor model-training settings are unknown
- AI changes are not logged anywhere
- Open legal/privacy/security questions have no owner

Evidence file checklist

Keep links or copies of these items together:

- ☐ Current AI Use Inventory
- ☐ Current AI Acceptable Use Policy
- ☐ Green / Yellow / Red AI Use Rules
- ☐ Completed AI Tool Approval Mini-Checklists
- ☐ Completed AI Risk Intake and Impact Assessments
- ☐ AI Risk Tiering Decision Tree records
- ☐ AI Risk Register

- ☐ AI Update Tracker
- ☐ Rollout email or message
- ☐ Meeting notes and decision log
- ☐ Vendor terms, privacy, security, and training-use notes
- ☐ Staff acknowledgments if collected
- ☐ Open-question list for legal/privacy/security/procurement review

Next-phase options

After the packet is in use, decide which area matters next:

If the next pain is...	Consider adding...
Vendor approvals are slow or inconsistent	Full Vendor AI Review Packet
Staff need structured instruction	AI Training Program Kit
Customer-facing AI needs disclosures	Customer AI Disclosure Templates
Incidents or harmful outputs are a concern	AI Incident Response Plan
Jurisdiction-specific exposure is growing	Relevant state/EU readiness kit
Higher-risk workflows are regulated or rights-affecting	Qualified legal, privacy, security, HR, or sector review

These are next-phase workstreams. Do not force them into the first pass unless the risk is already present.

30-day follow-up questions

Use these questions one month after rollout:

10. Which tools were added or removed?
11. Did anyone ask for a new AI tool or workflow?
12. Did any rule confuse staff?
13. Did any output create a quality, privacy, security, legal, customer, or reputational concern?
14. Were any vendor terms, model settings, or data-use policies changed?
15. Which risk register item matters most right now?
16. Which open action should be updated before the next quarterly review?

Disclaimer

This document is a template for educational and informational purposes only. It is not legal advice and does not create an attorney-client relationship. Consult qualified counsel before relying on this scorecard for compliance decisions.